

Pen Testing Course1

Rubric 2

Information Gathering and Assessment

Engagement title: Home Lab Internal Network Assessment **Phase:** PTES Phase 2–3
(Intelligence Gathering & Threat Modeling) **Document version:** 1.0 **Classification:** Confidential
— Lab Use Only **Prepared by:** *[Your name]*, DAE Cybersecurity Program **Date:** *[Fill in]* **Related documents:** Penetration Testing Methodology & Engagement Plan (Rubric 1)

This report is the reconnaissance stage of the same engagement defined in Rubric 1. The scope, target, and authorization all carry forward from that plan. Placeholders in *[brackets]* are yours to fill in.

Table of Contents

1. Objectives & Scope
 2. Ethical & Legal Framework
 3. Reconnaissance Methodology
 4. Passive Reconnaissance (OSINT)
 5. Active Network Enumeration
 6. Asset Discovery & Inventory
 7. Technical Findings & Potential Vulnerabilities
 8. Areas for Further Investigation
 9. Evidence Log
 10. Appendix A — Command Reference
 11. Appendix B — References
-

1. Objectives & Scope

Objectives for this phase:

1. Perform passive reconnaissance using multiple OSINT sources and document the methodology.
2. Perform active network enumeration with appropriate tools.

3. Discover and inventory every live system and running service in scope.
4. Identify potential vulnerabilities and areas needing deeper investigation.

Scope (carried forward from Rubric 1):

Asset	Identifier	Role
Ubuntu VM	192.168.78.5 (hostname Ubuntu)	Target
Lab subnet	192.168.78.0/24 — <i>confirm with ip a</i>	Testing network
Tester	Windows laptop	Scanning host

Out of scope: the VirtualBox host OS, your home router, and every device not on the lab subnet.

2. Ethical & Legal Framework

Reconnaissance is where ethics gets tested first, so state the boundaries explicitly.

- **Authorization:** All active enumeration is covered by the signed authorization form in Rubric 1, which permits testing of 192.168.78.5 only.
 - **Passive vs. active — why it matters legally:**
 - *Passive* reconnaissance uses publicly available information and never touches the target directly (WHOIS lookups, public DNS records, search engines). It generally does not require authorization because you are only reading public data.
 - *Active* reconnaissance sends packets to the target (ping sweeps, port scans). This **does** require authorization — unauthorized scanning of systems you don't own can violate computer-misuse laws.
 - **Authorized OSINT demonstration target:** Where a public target is needed to demonstrate OSINT methodology, only explicitly sanctioned targets are used — scanme.nmap.org (which Nmap authorizes for scan practice) or a domain the tester owns. No third-party systems are enumerated.
 - **Data handling:** All collected information stays on the lab machines and is treated as confidential.
-

3. Reconnaissance Methodology

The process follows a funnel: start wide and public, narrow to specific and technical.

Step	Type	Question it answers	Primary tools
1	Passive	What can be learned without touching the target?	WHOIS, dig/nslookup, Shodan, search engines, theHarvester
2	Active — host discovery	Which hosts on the subnet are alive?	Nmap <code>-sn</code> , arp-scan, netdiscover
3	Active — port scanning	Which ports are open on each host?	Nmap
4	Active — service enumeration	What software and versions are behind those ports?	Nmap <code>-sV</code> , <code>-sC</code>
5	Active — OS fingerprinting	What operating system is the host running?	Nmap <code>-O</code>
6	Analysis	Which findings are potential vulnerabilities?	Manual review against known-issue databases

4. Passive Reconnaissance (OSINT)

4.1 Sources and how to use them

OSINT source	What it reveals	How to query
WHOIS	Domain registration, owner, name servers	<code>whois example.com</code>

OSINT source	What it reveals	How to query
DNS records	IPs, mail servers, subdomains	<code>dig example.com any / nslookup example.com</code>
Search engines / dorks	Exposed pages, files, directories	<code>site:example.com filetype:pdf</code>
Shodan	Internet-exposed services and banners	shodan.io search by IP/domain
theHarvester	Emails, hostnames, subdomains from public sources	<code>theHarvester -d example.com -b all</code>
Wayback Machine	Historical versions of a site	web.archive.org

4.2 Findings for the in-scope target

The in-scope target `192.168.78.5` is a **private (RFC 1918) address on an isolated lab network**. Passive OSINT sources index the public internet, so they return **no results** for this host:

- WHOIS: N/A — private IP, not registered.
- Public DNS: N/A — the host has no public DNS record.
- Shodan: N/A — not internet-exposed.

This is a legitimate documented finding: the target has no external attack surface, so any attacker would need to already be on the local network. Record this in the report — it demonstrates you understand *why* the OSINT results are empty, which is the point.

4.3 Methodology demonstration (authorized public target)

(Optional, if your rubric wants OSINT with real output.) Run the passive workflow against `scanme.nmap.org` or your own domain and paste the results here — e.g. the WHOIS registrant, name servers, and any subdomains `dig`/theHarvester return. This shows the methodology producing real findings without touching any unauthorized system.

5. Active Network Enumeration

All commands below are authorized against the lab subnet. Install **Nmap** on the Windows tester (nmap.org — the installer includes the Zenmap GUI and the Npcap driver), or run them from a Linux/Kali box on the same network. Save every scan's output as evidence with the **-oN** flag.

5.1 Host discovery — find live systems

```
nmap -sn 192.168.78.0/24 -oN hosts.txt
```

- **-sn** = "ping scan": discover which hosts are up **without** port scanning them.
- Output lists every responding host on the subnet. Confirm **192.168.78.5** appears.

Layer-2 alternative (Linux only, more reliable on a local network):

```
sudo arp-scan --localnet
```

or

```
sudo netdiscover -r 192.168.78.0/24
```

5.2 Port scan — find open ports

```
nmap 192.168.78.5 -oN ports-top1000.txt
```

This scans the 1,000 most common TCP ports. To be thorough and scan **all** 65,535 ports:

```
nmap -p- 192.168.78.5 -oN ports-all.txt
```

- **-p-** = scan every port. Slower, but "comprehensive asset discovery" is a rubric requirement, so run it.
- **Expected result:** **23/tcp open telnet** (the service you configured). If you added SSH, **22/tcp open** will also appear.

5.3 Service & version detection

```
sudo nmap -sV 192.168.78.5 -oN services.txt
```

- **-sV** = probe open ports to identify the **service and version** (e.g., the exact telnetd banner). Version numbers are what you later match against known vulnerabilities.

5.4 Default scripts + OS detection (comprehensive scan)

```
sudo nmap -sC -sV -O -p- 192.168.78.5 -oN full-scan.txt
```

- **-sC** = run Nmap's default safe scripts (**-sC**) for extra detail (banners, config hints).
- **-O** = attempt **OS fingerprinting** (needs root/admin). Expected: Linux, matching your Ubuntu VM.
- Combining flags gives you one authoritative scan file for the report.

5.5 Verify from the target's own side

Confirm your external scan matches what the host actually exposes. On the Ubuntu VM:

```
sudo ss -tlnp
```

Every listening port here should correspond to an open port in your Nmap results. Discrepancies are worth noting (e.g., a port open locally but filtered by a firewall from the network).

6. Asset Discovery & Inventory

Consolidate the scan results into a clean inventory. Fill the version column from your **-sV** output.

6.1 Systems discovered

Host	IP	OS (from -O)	Role
Ubuntu	192.168.78.5	Linux (Ubuntu)	Target
[others found by -sn]			

6.2 Services discovered on 192.168.78.5

Port	Protocol	State	Service	Version (from -sV)	Notes
23/tcp	TCP	open	telnet	[e.g., <i>Linux telnetd</i>]	Unencrypted remote access

Port	Protocol	State	Service	Version (from -sV)	Notes
[22/tcp]	TCP	[open]	[ssh]	[OpenSSH x.x]	[if installed]

7. Technical Findings & Potential Vulnerabilities

Reconnaissance doesn't confirm exploitation — it flags candidates. Rate each by likely severity for triage.

ID	Finding	Why it's a concern	Preliminary severity
R-01	Telnet (23/tcp) open	Telnet transmits credentials in cleartext; anyone on the segment can intercept logins	High
R-02	[any outdated service version from -sV]	Old versions may have public CVEs	[TBD]
R-03	Host reachable across the lab segment	No network segmentation isolating the target	Low–Medium

Finding **R-01** is the through-line from Rubric 1 and the primary candidate for the exploitation phase.

8. Areas for Further Investigation

This feeds directly into the next phase (vulnerability analysis / exploitation):

1. **Confirm the telnet cleartext weakness (R-01)** by capturing a login with Wireshark or `tcpdump -A 'tcp port 23'` on the target — the packet contents will show credentials in plain text.
2. **Match discovered service versions against a vulnerability database** (NVD, Exploit-DB) for any known CVEs.

3. **Test credential strength** on exposed login services (within scope only).
4. **Check for other listening services** revealed by the full `-p-` scan that weren't expected.

9. Evidence Log

Capture and store each of these as proof of methodology:

- ☐ `hosts.txt` — host discovery output
- ☐ `ports-all.txt` — full port scan
- ☐ `services.txt` — version detection
- ☐ `full-scan.txt` — comprehensive scan with scripts and OS detection
- ☐ Screenshot of Zenmap topology or terminal scan (portfolio visual)
- ☐ `ss -tlnp` output from the target for cross-verification
- ☐ (Optional) OSINT output from the authorized public target

Appendix A — Command Reference

Goal	Command
Discover live hosts	<code>nmap -sn 192.168.78.0/24 -oN hosts.txt</code>
Scan all ports	<code>nmap -p- 192.168.78.5 -oN ports-all.txt</code>
Detect service versions	<code>sudo nmap -sV 192.168.78.5 -oN services.txt</code>
Full scan (scripts + OS)	<code>sudo nmap -sC -sV -O -p- 192.168.78.5 -oN full-scan.txt</code>
Verify from target	<code>sudo ss -tlnp</code>
Confirm target IP	<code>ip a</code>

Reading Nmap port states: `open` = a service is listening; `closed` = reachable but nothing listening; `filtered` = a firewall is blocking the probe.

Appendix B — References

- Penetration Testing Execution Standard (PTES), Intelligence Gathering — pentest-standard.org
- NIST SP 800-115, *Technical Guide to Information Security Testing and Assessment*
- Nmap Reference Guide — nmap.org/book/man.html
- OSINT Framework — osintframework.com
- National Vulnerability Database (NVD) — nvd.nist.gov

This report is for authorized security testing in a controlled lab environment only.